USO INTERNO — LABORATORIO PERSONALE

exa-dune

Framework Multi-Protocollo per Penetration Testing

Versione 2.8.0 — 25 Marzo 2026

Manuale operativo completo per l'utilizzo di exa-dune in ambienti IoT e VoIP. Questa versione documenta tutti i subcomandi disponibili, il sistema di bypass firewall avanzato a 32 tecniche, l'assessment automatico a 4 fasi (SCAN → ENUM → ATTACCHI → REPORT), il credential store e i profili device per AudioCodes, Commend, GAI-Tronics, Axis e Reolink.

35+	32	13.5k	6
SUBCOMANDI	BYPASS FW	RIGHE CODICE	VENDOR CVE

Autore: Security Lab — Piattaforma: Kali Linux 6.18 — GitHub: github.com/Sal1699/exa-dune

CONFIDENZIALE — USO ESCLUSIVAMENTE IN AMBIENTI AUTORIZZATI

Indice dei Contenuti

0. Cover Page 1

1. Introduzione 2

2. Installazione 4

3. Architettura 6

4. Flag Globali 8

5. Comando AUTO — Assessment Completo a 4 Fasi 10

5.1 FASE 1 — SCAN (pre-scan + scan principale + post-scan) 11

5.2 Firewall Bypass — 32 Tecniche 14

5.3 FASE 2 — ENUMERAZIONE 17

5.4 FASE 3 — ATTACCHI 21

5.5 FASE 4 — REPORT PDF 24

5.6 Checkpoint e Resume 25

6. Riferimento Completo Comandi 26

7. Scenari Pratici di Laboratorio 48

8. Cheat Sheet Rapido 54

9. Changelog 56

1. Introduzione

1.1 Cos'è exa-dune?

exa-dune è un framework di penetration testing scritto in Bash (~13.500 righe), progettato per ambienti **IoT** e **VoIP**. Integra e coordina oltre 40 tool di sicurezza di Kali Linux attraverso un'interfaccia unificata a subcomandi, automatizza il ciclo completo di assessment e genera report in italiano con scoring CVSS 3.1.

> **AVVERTENZA LEGALE**
>
> Questo strumento è destinato **esclusivamente** a sistemi di tua proprietà o per i quali hai esplicita autorizzazione scritta. L'uso non autorizzato costituisce reato penale in Italia e in tutti i paesi dell'UE.

1.2 Cosa può fare exa-dune v2.8.0?

- **35+ subcomandi** — dalla scansione alla post-exploitation, copertura completa
- **Assessment automatico a 4 fasi** — un solo comando `auto` esegue scan, enum, attacchi e report PDF
- **32 tecniche di bypass firewall** — ACK, FIN, frammenti IP, source port spoofing, UPnP, SIP-ALG, port knocking, IoT vendor ports e altro
- **Enumerazione multi-protocollo** — HTTP, HTTPS, SIP, SIP-WS, SSH, Telnet, FTP, RTSP, ONVIF, SNMP, TFTP, MQTT, SMB, UPnP, Modbus, BACnet, EtherNet/IP, CoAP, IPMI, DNS, RTMP, RDP, VNC, LDAP, Asterisk AMI, DLNA, STUN, MGCP, H.248, S7comm, DNP3
- **CVE database integrato** — Hikvision, Dahua, Axis, Reolink, AudioCodes MP20x, Commend ET962
- **Credential store** — credenziali trovate salvate e correlate cross-service
- **Sistema checkpoint/resume** — riprendi assessment interrotti senza perdere il lavoro svolto
- **Pipeline automatizzata** — scan → suggest → attacchi → post-exploit → PDF
- **Wordlist embedded** — funziona anche senza SecLists installato

1.3 Device supportati nel laboratorio

TIPO	MODELLO	IP LAB	PROTOCOLLI PRINCIPALI	VENDOR CVE
VoIP Gateway	AudioCodes MP20x	192.168.1.x	SIP, SNMP v2c, HTTP, TFTP	audiocodes
SIP Station	Commend ET962-BF5xx	192.168.1.x	SIP, HTTP, RTSP	commend
Commander VoIP	GAI-Tronics	192.168.1.x	SIP, HTTP	generic
IP Camera	Axis (vari)	192.168.2.x	RTSP, ONVIF, HTTP, SNMP	axis
IP Camera	Reolink (vari)	192.168.2.x	RTSP, ONVIF, HTTP, porta 9000	reolink
IoT Adapter	Sconosciuto	192.168.1.x	Variabile	auto-detect

RETI DEL LABORATORIO

Le reti del lab sono **192.168.1.0/24** (VoIP/IoT) e **192.168.2.0/24** (telecamere). L'attaccante si trova a **192.168.1.100** / **192.168.2.100**.

2. Installazione

2.1 Clone e installazione

```
# Clone dal repository GitHub
git clone https://github.com/Sal1699/exa-dune.git
cd exa-dune
sudo cp exa-dune /usr/local/bin/exa-dune
chmod +x /usr/local/bin/exa-dune

# Installa le dipendenze mancanti
sudo exa-dune install

# Verifica versione
exa-dune --version
```

2.2 Self-test

```
# Verifica disponibilità di tutti i tool necessari
exa-dune self-test

# Installa automaticamente i tool mancanti
exa-dune self-test --install-missing
```

Il self-test verifica la disponibilità di: nmap, hydra, nikto, gobuster, svmap, svwar, svcrack, mosquitto_sub, ffmpeg, testssl.sh, sslscan, openssl, curl, atftp, nc, enum4linux, smbclient, snmpwalk, searchsploit, arp-scan, dnsrecon, ldapsearch, ipmitool, dig, traceroute, tcpdump, python3, sqlite3 e altri.

2.3 Struttura directory output

```
/root/pentest/exa-dune-<TARGET>_<TIMESTAMP>/
  scan/
    nmap_fast.nmap         # nmap top 1000 TCP + service detection
```

```
    nmap_fast.xml          # per searchsploit --nmap
    nmap_full.nmap         # nmap -p- (tutte le porte)
    nmap_udp.nmap          # UDP top 20
    arp.txt                # MAC address e vendor OUI
    searchsploit.txt       # CVE da banner nmap
  prescan/
    dns.txt                # PTR record
    arp_passive.txt        # ARP sniff passivo
    http_head.txt          # HTTP HEAD :80/:443/:8080/:8443
    ssl_cert.txt           # CN/SAN/O dal certificato :443
    snmp_quick.txt         # community SNMP che risponde
    mac.txt                # MAC + vendor OUI
  web/                     # nikto, gobuster, curl headers
  sip/                     # svmap, svwar, svcrack
  fw/                      # bypass firewall (32 tecniche)
  nse_targeted/            # NSE scripts mirati post-discovery
  unknown_ports/           # banner grab porte non standard
  msf/                     # Metasploit CVE check
  device_profile.txt       # profilo consolidato del device
  findings.txt             # tutti i finding per severità
  master.log               # log completo sessione auto
  .exa_checkpoint          # checkpoint per resume
  .exa_creds.json          # credential store
  REPORT_*.pdf             # report finale
```

3. Architettura

3.1 Flusso del comando `auto`

FASE 1 SCAN → **FASE 2** ENUM → **FASE 3** ATTACCHI → **FASE 4** REPORT

La logica di branching nella FASE 1 è a tre rami:

- **Ramo 1 (normale):** scan trova porte/servizi → si procede direttamente con la FASE 2
- **Ramo 2 (bypass):** scan non trova nulla → si tenta il bypass firewall con 32 tecniche → se una funziona si torna alla FASE 2
- **Ramo 3 (fallback):** bypass fallisce completamente → si salta direttamente alla FASE 4 con un report "no access"

3.2 Componenti principali

COMPONENTE	DESCRIZIONE
`exa-dune`	Script Bash principale (~13.500 righe, 35+ subcomandi)
`prescan/`	Ricognizione passiva pre-scan (DNS, ARP, SNMP, HTTP HEAD, SSL cert)
`nse_targeted/`	NSE scripts mirati su servizi rilevati in FASE 2
`.exa_checkpoint`	File di checkpoint per resume (un modulo per riga)
`.exa_creds.json`	Credential store JSON per la sessione corrente
`device_profile.txt`	Profilo consolidato: vendor, MAC, porte, servizi, finding count
Wordlist embedded	8 categorie di wordlist integrate nello script (fallback senza SecLists)

3.3 Credential Store

Ogni credenziale trovata durante il test viene salvata in `.exa_creds.json` per servizio, host e porta. Al termine della FASE 3, exa-dune esegue una correlazione cross-service: testa le credenziali trovate su tutti gli altri servizi aperti del target.

```
[OK] SNMP community 'public' trovata → salvata in .exa_creds.json
[OK] SSH admin:admin123 trovata (hydra) → salvata in .exa_creds.json
[OK] HTTP Admin:Admin trovata (quick-default) → salvata in .exa_creds.js

── Correlazione credenziali cross-service ──
[FOUND:CRITICAL] Credential reuse: admin:admin123 funziona su Telnet (19
[FOUND:HIGH]     Credential reuse: Admin:Admin funziona su FTP (192.168.
```

4. Flag Globali

4.1 Flag disponibili su tutti (o quasi) i moduli

FLAG	DESCRIZIONE	DEFAULT
`--dry-run`	Mostra i comandi che verrebbero eseguiti senza eseguirli. Utile per verifica pre-lancio.	off
`--stealth`	Abilita modalità stealth: nmap -T2, rate ridotto, attività minima. Riduce il rumore di rete.	off
`--timeout N`	Timeout in minuti per ogni modulo/tool. Previene blocchi su host lenti o irraggiungibili.	60
`--output DIR`	Directory di output base. Se non specificata, viene creata automaticamente in /root/pentest/.	auto
`--userlist FILE`	File wordlist utenti custom (sovrascrive la wordlist embedded).	embedded
`--passlist FILE`	File wordlist password custom (sovrascrive la wordlist embedded).	embedded
`--help / -h`	Mostra l'help del subcomando specifico.	—

4.2 Variabili d'ambiente

VARIABILE	DESCRIZIONE
`NMAP_OPTS_EXTRA`	Opzioni aggiuntive passate a tutti i comandi nmap (es. `-Pn` per host senza ICMP)
`ADAPTIVE`	Se =1, abilita rate limiting adattivo basato sui tempi di risposta nmap
`PROPAGATE_CREDS`	Se =1, abilita propagazione automatica credenziali al termine della FASE 3

JSON_OUTPUT	Se =1, scrive findings.json oltre a findings.txt

4.3 Esempi di utilizzo flag

```
# Modalità dry-run: vedi cosa farebbe exa-dune senza eseguire nulla
exa-dune auto 192.168.1.10 --dry-run

# Modalità stealth con timeout 30 minuti e wordlist custom
exa-dune auto 192.168.1.10 --stealth --timeout 30 \
  --userlist /root/pentest/users.txt \
  --passlist /root/pentest/pass.txt

# Output in directory specifica
exa-dune scan 192.168.2.50 --output /root/pentest/assessment-axis/

# Mostra help di un subcomando
exa-dune auto --help
exa-dune fw --help
```

5. Comando AUTO — Assessment Completo a 4 Fasi

`auto` è il comando principale di exa-dune: esegue un assessment completo e automatizzato di un target, dall'identificazione iniziale fino alla generazione del report PDF, tutto in un singolo terminale con output in tempo reale.

5.0 Sintassi

```
exa-dune auto <TARGET> [OPTIONS]

# TARGET può essere un indirizzo IP o un hostname
exa-dune auto 192.168.1.10
exa-dune auto audiocodes.lab.local
```

5.0.1 Opzioni specifiche di auto

OPZIONE	DESCRIZIONE
`--stealth`	Modalità stealth: scan lento, rate ridotto, timing nmap T2
`--timeout N`	Timeout in minuti per ogni modulo (default: 60). Ogni modulo viene wrappato con `timeout N*60s exa-dune ...`
`--userlist FILE`	Wordlist utenti custom per brute-force (propagata a tutti i moduli)
`--passlist FILE`	Wordlist password custom (propagata a tutti i moduli)
`--output DIR`	Directory di output. Se non specificata: `/root/pentest/exa-dune-TARGET_TIMESTAMP/`
`--resume DIR`	Riprende assessment da una directory esistente, saltando i moduli già completati (usa .exa_checkpoint)
`--dry-run`	Mostra i comandi senza eseguirli, usando un piano attacchi demo

5.1 FASE 1 — SCAN

La FASE 1 è suddivisa in tre sotto-fasi: **pre-scan** (ricognizione passiva/veloce), **scan principale** (nmap completo), **post-scan** (MAC vendor lookup).

Pre-scan (9 operazioni)

#	OPERAZIONE	TOOL	SCOPO
1	DNS reverse lookup	dig, host	Ricava hostname dal PTR record — rivela spesso modello e vendor
2	Passive ARP sniff (10s)	tcpdump	Cattura trame ARP senza inviare pacchetti — ottiene MAC address in modo stealth
3	ICMP ping check	ping	Decide se usare `-Pn` negli scan successivi. Se ICMP bloccato: imposta NMAP_OPTS_EXTRA=-Pn
4	Traceroute	traceroute	Conta gli hop, rileva NAT/firewall intermedi confrontando ultimo hop con target IP
5	mDNS discovery	exa-dune mdns (UDP 5353)	Dispositivi IoT si auto-annunciano via mDNS (Avahi, Bonjour)
6	WS-Discovery probe	exa-dune wsd (UDP 3702)	Telecamere e device embedded annunciano servizi ONVIF/WSDL
7	SNMP quick probe	snmpget	Prova community public/private/community/admin su UDP 161. Se risponde: salva in snmp_quick.txt
8	HTTP HEAD rapido	curl	Porta 80, 443, 8080, 8443. Il header *Server:* rivela spesso modello e versione firmware
9	SSL certificate grab	openssl s_client	CN/SAN/O del certificato :443 contengono spesso vendor e modello device

Scan principale

- **nmap fast** — top 1000 porte TCP, `-sV -sC -O`, service detection + script default
- **nmap full** — tutte le porte TCP `-p-` (saltabile con `--no-full`)
- **nmap UDP** — top 20 porte UDP più comuni
- **ARP scan** — rileva MAC address e vendor OUI
- **searchsploit** — ricerca CVE dal XML nmap: `searchsploit --nmap nmap_fast.xml`

Post-scan

Dopo lo scan, exa-dune effettua il **MAC vendor lookup** dal file `arp.txt` (prodotto da arp-scan) e aggiunge il risultato al contesto di pre-scan per migliorare il riconoscimento del device nella FASE 2.

Logica a 3 rami

Al termine della FASE 1, exa-dune controlla se ha trovato punti deboli verificando: porte aperte TCP/UDP, MAC/vendor rilevato, hostname DNS, risposta HTTP HEAD, certificato SSL, mDNS/WSD findings, risposta SNMP, ARP passivo, traceroute arrivato al target, match searchsploit.

- Se **almeno uno** di questi è positivo → **FASE 2 ENUMERAZIONE**
- Se **nessuno** → tenta **bypass firewall** (32 tecniche)
- Se bypass fallisce → **FASE 4 REPORT** con `no_access_summary.txt`

5.2 Firewall Bypass — 32 Tecniche

Quando lo scan non rileva nulla, exa-dune testa automaticamente 32 tecniche di bypass, implementate nel modulo `fw` richiamato da `auto`. Il modulo `fw` può anche essere invocato direttamente (`exa-dune fw TARGET`).

#	TECNICA	COMANDO / MECCANISMO
1	ACK scan	`nmap -sA` — distingue stateful da stateless: porte *unfiltered* sono raggiungibili
2	FIN scan	`nmap -sF` — bypass firewall che filtrano solo SYN
3	NULL scan	`nmap -sN` — nessun flag TCP impostato

4	XMAS scan	`nmap -sX` — flag FIN+URG+PSH
5	Maimon scan	`nmap -sM` — FIN+ACK
6	Window scan	`nmap -sW` — analizza TCP window size nella risposta RST
7	Source port spoofing	`nmap --source-port` con porte 53, 20, 21, 80, 443, 123, 554, 3389, 5060, 500, 179, 1194
8	IP fragmentation (-f)	`nmap -f` — frammenti da 8 byte
9	IP fragmentation MTU 8	`nmap --mtu 8`
10	IP fragmentation MTU 24	`nmap --mtu 24`
11	Decoy scan	`nmap -D RND:10` — camuffa l'IP sorgente con 10 decoy casuali
12	TTL manipulation	`nmap --ttl 64/128/255` — alcuni firewall filtrano su TTL
13	Data-length padding	`nmap --data-length N` — aggiunge padding casuale ai pacchetti
14	Slow scan	`nmap -T1 --scan-delay 2s` — evasione IDS rate-based
15	Bad checksum	`nmap --badsum` — distingue firewall (droppa) da IDS (risponde)
16	UPnP AddPortMapping	SOAP WANIPConnection/WANPPPConnection — richiede apertura porta arbitraria
17	SIP ALG pinhole	INVITE + REGISTER + OPTIONS su porta SIP — alcuni NAT/FW aprono pinhole per SIP
18	FTP ALG PORT command	Comando PORT FTP — alcuni firewall aprono connessioni data FTP attraverso il NAT
19	HTTP CONNECT tunnel	Prova proxy HTTP CONNECT su porte comuni — tunnel attraverso proxy trasparenti

20	IPv6 link-local	Calcola indirizzo EUI-64 dal MAC (fe80::.../64) e riprova scan in IPv6
21	IPv6 globale (AAAA DNS)	Risolve record AAAA e ripete scan su IPv6 globale
22	Protocol confusion	SSH su 443, SIP su 80, HTTP su 22 — alcuni firewall filtrano per porta non per protocollo
23	ICMP tipo 13	Timestamp request — spesso non filtrato dove l'echo è bloccato
24	ICMP tipo 17	Netmask request — rivela subnet mask senza aprire porte TCP
25	SNMP recon ifTable	Walk MIB ifTable (1.3.6.1.2.1.2.2) — rivela interfacce di rete e IP alias
26	SNMP recon ipRouteTable	Walk ipRouteTable (1.3.6.1.2.1.4.21) — rivela routing interno e subnet raggiungibili
27	SNMP recon tcpConnTable	Walk tcpConnTable (1.3.6.1.2.1.6.13) — rivela connessioni TCP attive e porte in ascolto
28	IoT vendor ports — Dahua	Porta 37777 (accesso API proprietario Dahua)
29	IoT vendor ports — Hikvision	Porta 8000 (SDK client Hikvision)
30	IoT vendor ports — vari	Reolink 9000, MikroTik 8291 (Winbox), TR-069 7547, Asterisk AMI 5038, HTTP-alt 8888/9090
31	Port knocking	10 sequenze comuni IoT/embedded — bussare porte in sequenza sblocca il firewall
32	Full port scan 1-65535	`nmap -p1-65535 -T2` — scan lento completo come ultima risorsa

USO MANUALE DEL MODULO FW

Puoi anche invocare il modulo fw direttamente per testare tecniche specifiche:

```
exa-dune fw 192.168.1.10 --tech ack,altscans,srcport --ports
22,80,443,5060
```

5.3 FASE 2 — ENUMERAZIONE

La FASE 2 lancia automaticamente i moduli di enumerazione appropriati in base alle porte aperte trovate nella FASE 1. Prima di tutto, exa-dune aggrega il contesto del pre-scan (HTTP Server header, SSL CN/O, SNMP sysDescr, DNS hostname, mDNS/WSD findings, MAC OUI, SNMP OID enterprise) per rilevare il vendor del device.

Rilevamento vendor automatico

Il contesto pre-scan viene confrontato con pattern per identificare: **audiocodes**, **commend**, **gai-tronics**, **axis**, **reolink**, **hikvision**, **dahua**. Anche l'OID SNMP enterprise viene mappato al vendor (es. `1.3.6.1.4.1.591.*` = AudioCodes).

Moduli standard attivati per porta

PORTO/PROTOCOLLO	MODULO	CONDIZIONE DI ATTIVAZIONE
`80` `8000` `8080`	web (HTTP)	porta TCP aperta
`443` `8443`	web (HTTPS)	porta TCP aperta
`443` `8443`	ssl	almeno una porta HTTPS aperta
porte web qualsiasi	js	qualsiasi porta web aperta (analisi JavaScript)
`5060` `5061`	sip	porta TCP/UDP aperta
porte web + SIP	SIP-WS probe	HTTP Upgrade WebSocket con Sec-WebSocket-Protocol: sip
`22`	ssh	porta TCP aperta
`23`	telnet	porta TCP aperta
`21`	ftp	porta TCP aperta

`554` `8554`	rtsp	porta TCP aperta
RTSP + web / vendor camera	onvif	RTSP + HTTP oppure is_camera=1
`161` `162`	snmp	porta UDP aperta o snmp_quick.txt non vuoto
`69`	tftp	porta UDP aperta
`1883`	mqtt	porta TCP aperta
`445`	smb	porta TCP aperta
`1900`	upnp	porta UDP aperta
`502`	modbus	porta TCP aperta
`47808`	bacnet	porta UDP aperta
`44818`	enip	porta TCP aperta (EtherNet/IP)
`5683`	coap	porta UDP aperta
`623`	ipmi	porta UDP aperta
`53`	dns	porta TCP aperta
`1935`	rtmp	porta TCP aperta
`3389`	rdp	porta TCP aperta
`5900`	vnc	porta TCP aperta
`389` `636`	ldap	porta TCP aperta

Porte non-standard per protocolli noti

PORTA	PROTOCOLLO	NOTA

`2222` `2200`	SSH	Comune su device embedded/IoT
`2323` `4567`	Telnet	2323 sui router IoT, 4567 su VoIP
`10554` `8899`	RTSP	Reolink 10554, Hikvision/altri 8899
`8883`	MQTT-TLS	MQTT over TLS (standard)

Protocolli addizionali IoT/VoIP/Industrial

- **Asterisk AMI** (porta 5038): banner grab, login con 5 credenziali default, dump SIPpeers se accesso riuscito
- **DLNA/UPnP media server** (porta 8200): rootDesc.xml, Content Directory SOAP browse senza auth
- **STUN** (UDP 3478): nmap script `stun-info`
- **MGCP** (UDP 2427): nmap script `mgcp-request`, endpoint enumeration
- **H.248/Megaco** (TCP 2944): banner probe binario, nmap banner
- **S7comm/Profinet** (TCP 102): nmap script `s7-info` — PLC Siemens
- **DNP3** (TCP/UDP 20000): nmap script `dnp3-info` — SCADA/ICS

Moduli vendor-specifici

Se il vendor viene identificato, viene lanciato il modulo `cam-cve` con `--vendor VENDOR` per testare CVE specifici. Se il device è una camera ma il vendor non è identificato, viene comunque lanciato `cam-cve` generico.

NSE scripts mirati post-discovery

Dopo i moduli standard, exa-dune esegue NSE scripts Nmap mirati sui servizi trovati:

- **HTTP:** http-auth-finder, http-default-accounts, http-methods, http-headers, http-robots.txt
- **FTP:** ftp-anon, ftp-bounce, ftp-syst
- **SSH:** ssh2-enum-algos, ssh-hostkey, ssh-auth-methods
- **SMB:** smb-vuln-ms17-010, smb-vuln-ms08-067, smb-security-mode, smb2-security-mode
- **SNMP:** snmp-brute, snmp-info, snmp-interfaces
- **VNC:** vnc-info, realvnc-auth-bypass

- **RTSP:** rtsp-url-brute, rtsp-methods
- **SIP:** sip-enum-users, sip-methods
- **RDP:** rdp-enum-encryption, rdp-vuln-ms12-020
- **MQTT:** mqtt-subscribe

Banner grab su porte sconosciute

Per ogni porta TCP aperta non coperta da moduli specifici, exa-dune esegue: nmap `-sV` sulla porta, banner grab raw con nc, HTTP HEAD (http e https), e infine searchsploit sul banner/versione rilevata per trovare CVE noti.

Fallback intelligente (nessuna porta trovata)

Se nessun modulo si è attivato (ran_enum=0), exa-dune usa i dati del pre-scan per decidere cosa fare: se HTTP HEAD ha risposto, lancia web; se SNMP ha risposto, lancia snmp; se vendor è camera/voip, lancia i moduli appropriati. Come ultima risorsa: web:80, sip, snmp, ssh.

Device profile consolidato

Al termine della FASE 2, viene generato `device_profile.txt` con: target, hostname DNS, vendor rilevato, tipo device (camera/VoIP), MAC e vendor OUI, SSL CN/O, porte aperte TCP/UDP, servizi nmap -sV, risposta SNMP, conteggio findings per severità (CRITICAL/HIGH/MEDIUM/LOW), top findings, credenziali trovate, NSE hits.

5.4 FASE 3 — ATTACCHI

La FASE 3 esegue attacchi mirati basati sui risultati della FASE 2. Ogni attacco è condizionato alla presenza del servizio corrispondente (porta aperta O finding nella FASE 2).

CVE exploitation via Metasploit

Se searchsploit ha trovato CVE nella FASE 1, exa-dune cerca i corrispondenti moduli Metasploit (fase A: `search cve:XXXX-YYYY`), poi esegue il comando `check` (non exploit!) su ciascuno. Se il check risponde "appears to be vulnerable", registra un finding CRITICAL.

Quick default IoT credentials

Prima del brute-force completo con hydra, exa-dune testa rapidamente 10 coppie di credenziali default comuni su ogni porta web aperta (HTTP basic auth con curl).

Se una funziona, la salva nel credential store e procede.

Rate limiting detection

Prima del brute-force HTTP, exa-dune rileva rate limiting (HTTP 429/503) e backoff progressivo. Se rilevato, adatta i parametri hydra (`-t 1 -W 5`) per evitare blocchi.

Brute-force credenziali

SERVIZIO	TOOL	PORTE
HTTP	hydra (via cmd_creds)	80, 8080
HTTPS	hydra (via cmd_creds)	443, 8443
SSH	hydra (via cmd_creds)	22
Telnet	hydra (via cmd_creds)	23
FTP	hydra (via cmd_creds)	21
SMB	hydra (via cmd_creds)	445
RDP	hydra (via cmd_creds)	3389
VNC	hydra (via cmd_creds)	5900
MQTT	hydra diretto	1883
LDAP	hydra diretto (ldap2)	389

Attacchi specializzati

- **IPMI cipher-zero:** testa ipmitool con `-C 0` (algoritmo di autenticazione nullo) — bypass auth completo su IPMI vulnerabili
- **SNMP write community:** testa snmpset con community private/write/admin/rw/manager/secret — se accettato registra CRITICAL
- **TFTP file disclosure:** tenta download di startup-config, running-config, config.bin, passwd, shadow, AudioCodes.ini, sip.conf e altri file sensibili
- **Web path traversal:** 6 payload (../etc/passwd, URL encoding, double encoding, Windows win.ini) su ogni porta web
- **SMB vuln scan:** NSE smb-vuln-ms17-010, smb-vuln-ms08-067, smb-vuln-cve-2020-0796

- **RTSP anonymous access:** DESCRIBE senza credenziali su path comuni (/, /live, /stream, /h264/ch1/main/av_stream Hikvision, /cam/realmonitor Dahua, /axis-media/media.amp Axis, /h264Preview_01_main Reolink)
- **UPnP AddPortMapping injection:** SOAP WANIPConnection per aprire port forwarding arbitrario
- **CoAP unauthenticated access:** GET /.well-known/core + POST su ogni risorsa trovata
- **DNS zone transfer (AXFR):** prova con hostname rilevato e domini locali (local, lan, home, internal)
- **Default creds vendor-specifiche:** AudioCodes (Admin:Admin, admin:AudioCodes...), Commend, Axis (root:pass, root:axis...), Reolink (admin:), Hikvision (admin:12345, admin:Admin12345...), Dahua (admin:admin, 666666:666666...)

5.5 FASE 4 — REPORT PDF

La FASE 4 raccoglie tutti i risultati e genera il report finale:

- Invoca `exa-dune report OUTDIR_BASE --pdf`
- Copia il PDF in `~/Desktop/EXA-DUNE-Reports/REPORT_TARGET_TIMESTAMP.pdf`
- Invia notifica desktop tramite `notify-send` (se disponibile)
- Crea archivio `tar.gz` compresso dell'intera directory output

Il report include: device profile, porte aperte, findings per severità (CRITICAL/HIGH/MEDIUM/LOW), credenziali trovate, CVE identificati, NSE hits, timeline operazioni.

5.6 Checkpoint e Resume

exa-dune salva automaticamente il progresso nel file `.exa_checkpoint` (una riga per ogni modulo/operazione completata). Se l'assessment viene interrotto, può essere ripreso con `--resume`.

```
# Avvio assessment normale
exa-dune auto 192.168.1.10 --output /root/pentest/assessment-ac/

# Se interrotto, riprendi da dove si era fermato
exa-dune auto 192.168.1.10 --resume /root/pentest/assessment-ac/
```

Il sistema legge `.exa_checkpoint` e salta i moduli già completati (*skip* visibile a schermo con il simbolo ↷). I moduli non completati vengono eseguiti normalmente. Se il checkpoint non esiste in `--resume`, il comando termina con errore.

5.7 Esempi pratici

```
# Assessment completo di un VoIP gateway AudioCodes
exa-dune auto 192.168.1.10

# Assessment stealth con timeout 30 minuti
exa-dune auto 192.168.1.10 --stealth --timeout 30

# Assessment con wordlist custom e output dedicato
exa-dune auto 192.168.2.50 \
  --userlist /usr/share/seclists/Usernames/top-usernames-shortlist.txt \
  --passlist /usr/share/seclists/Passwords/Common-Credentials/top-20-com
  --output /root/pentest/axis-cam/

# Solo dry-run — vedi cosa farebbe
exa-dune auto 192.168.1.20 --dry-run

# Riprendi un assessment interrotto
exa-dune auto 192.168.1.20 --resume /root/pentest/exa-dune-192-168-1-20_
```

6. Riferimento Completo Comandi

Per ogni subcomando viene riportata la descrizione, la sintassi completa, le opzioni principali e un esempio pratico di utilizzo nel laboratorio.

scan

Port scan + fingerprinting + recon — wraps nmap, arp-scan, searchsploit

```
exa-dune scan <TARGET> [--stealth] [--udp-top N] [--no-full] [--vu
```

OPZIONE	DESCRIZIONE
`--stealth`	nmap -T2, rate ridotto
`--udp-top N`	Numero porte UDP top-N da scansionare (default: 20)
`--no-full`	Salta il full scan nmap -p- (più veloce)
`--vuln`	Esegue nmap --script vuln + searchsploit per ogni banner

Esegue: ARP scan, nmap fast (top 1000 TCP -sV -sC -O), nmap full (-p-), nmap UDP (top N), searchsploit dal XML nmap. Al termine stampa un piano attacchi suggerito basato sulle porte trovate.

```
# Esempio: scan completo AudioCodes MP20x
exa-dune scan 192.168.1.10 --vuln --output /root/pentest/ac-scan/

# Esempio: scan veloce senza full port
exa-dune scan 192.168.2.50 --no-full --udp-top 50
```

web Web application audit — wraps nikto, gobuster, curl, nmap http NSE, ffuf

```
exa-dune web <TARGET> [--port PORT] [--scheme http|https] [--wordl
```

OPZIONE	DESCRIZIONE
`--port PORT`	Porta HTTP/HTTPS (default: 443)
`--scheme http|https`	Schema da usare (default: https)
`--wordlist FILE`	Wordlist custom per gobuster directory fuzzing
`--threads N`	Thread paralleli gobuster (default: 20)
`--fuzz`	Abilita fuzzing parametri GET con ffuf/wfuzz

Esegue: curl headers (Server, X-Powered-By, cookie flags, HSTS), nikto vulnerability scan, gobuster directory fuzzing, nmap http NSE (auth-finder, default-accounts, methods, robots.txt). Analizza JWT, certificati SSL, metodi HTTP pericolosi (TRACE/PUT/DELETE), SQLi e XXE.

```
# Audit interfaccia web AudioCodes su HTTPS:443
exa-dune web 192.168.1.10 --port 443 --scheme https

# Audit su porta non standard con fuzzing
exa-dune web 192.168.1.10 --port 8080 --scheme http --fuzz
```

sip SIP VoIP enumeration — wraps svmap, svwar, svcrack, nmap sip NSE

```
exa-dune sip <TARGET> [--port PORT] [--range 100-200] [--output DI
```

OPZIONE	DESCRIZIONE
`--port PORT`	Porta SIP (default: 5060)
`--range START-END`	Range estensioni per svwar (default: 100-500)

Esegue: svmap (device detection), svwar (extension enumeration), svcrack (PIN brute-force su estensioni trovate), nmap script sip-enum-users e sip-methods. Identifica proxy SIP, server PBX, UA type e versione firmware VoIP.

```
# Enum SIP su AudioCodes MP20x
exa-dune sip 192.168.1.10 --range 100-999

# SIP su porta non standard
exa-dune sip 192.168.1.30 --port 5061
```

smb

SMB/NetBIOS enumeration — wraps enum4linux, smbclient, nmap smb NSE

```
exa-dune smb <TARGET> [--output DIR] [--dry-run]
```

Esegue: enum4linux (utenti, share, policy, gruppo), smbclient (lista share anonymous), nmap NSE (smb-vuln-ms17-010, smb-vuln-ms08-067, smb-security-mode, smb2-security-mode). Rileva EternalBlue, SMBGhost, signing non obbligatorio.

```
# Enumera SMB su device con Windows embedded
exa-dune smb 192.168.1.50
```

creds

Credential brute-force multi-protocollo — wraps hydra

```
exa-dune creds <TARGET> <PROTOCOL> [--port PORT] [--userlist FILE]
```

Protocolli supportati: `http`, `https`, `ssh`, `ftp`, `telnet`, `smb`, `rdp`, `vnc`. Usa hydra con wordlist embedded o custom. Salva i risultati in hydra_PROTOCOL_PORT.txt.

```
# Brute-force SSH
exa-dune creds 192.168.1.10 ssh

# Brute-force HTTPS con wordlist custom
exa-dune creds 192.168.1.10 https --port 8443 \
  --userlist users.txt --passlist pass.txt
```

snmp

SNMP audit completo — wraps snmpwalk, nmap snmp NSE

```
exa-dune snmp <TARGET> [--community STR] [--version 1|2c|3] [--outp
```

Esegue: brute-force community string, snmpwalk MIB completo (system, interfaces, routing, TCP connections, porte in ascolto), nmap snmp-brute/snmp-info/snmp-interfaces. Estrae: sysDescr, sysName, sysObjectID (vendor mapping), ifTable, ipRouteTable, tcpConnTable.

```
# Audit SNMP AudioCodes (community public nota)
exa-dune snmp 192.168.1.10 --community public

# Audit con brute-force community
exa-dune snmp 192.168.1.10
```

ftp FTP audit — test accesso anonimo, banner grab, brute-force hydra

```
exa-dune ftp <TARGET> [--port PORT] [--output DIR]
```

Esegue: banner grab, test accesso anonimo (anonymous:anonymous), listing directory root, hydra brute-force, nmap ftp-anon/ftp-bounce/ftp-syst NSE.

```
exa-dune ftp 192.168.1.10
```

ssh SSH audit + brute-force — wraps hydra, nmap ssh NSE

```
exa-dune ssh <TARGET> [--port PORT] [--userlist FILE] [--passlist F
```

Esegue: banner grab (versione SSH), nmap ssh2-enum-algos/ssh-hostkey/ssh-auth-methods, hydra brute-force. Rileva algoritmi deboli (arcfour, 3des-cbc, diffie-hellman-group1), autenticazione con password abilitata.

```
# SSH su porta standard
exa-dune ssh 192.168.1.10

# SSH su porta non standard (IoT common)
exa-dune ssh 192.168.1.10 --port 2222
```

telnet Telnet banner grab + brute-force — wraps hydra

```
exa-dune telnet <TARGET> [--ports LIST] [--userlist FILE] [--passl
```

Esegue: banner grab con nc (identifica device da banner), hydra brute-force. Supporta porte alternative (2323, 4567). Il banner Telnet dei VoIP gateway rivela spesso versione firmware e modello.

```
exa-dune telnet 192.168.1.10
exa-dune telnet 192.168.1.10 --ports 23,2323
```

mqtt

MQTT broker audit — wraps mosquitto_sub, nmap mqtt NSE

```
exa-dune mqtt <TARGET> [--port PORT] [--output DIR]
```

Esegue: connessione anonima mosquitto_sub, subscribe a topic # (tutti), nmap mqtt-subscribe NSE. Rileva broker senza autenticazione, topic esposti, messaggi in chiaro. Supporta porta 8883 (MQTT-TLS).

```
exa-dune mqtt 192.168.1.20 --port 1883
exa-dune mqtt 192.168.1.20 --port 8883 # MQTT-TLS
```

modbus

Modbus/ICS audit — wraps nmap modbus NSE, raw probes TCP:502

```
exa-dune modbus <TARGET> [--output DIR]
```

Esegue: nmap modbus-discover NSE (unit ID enumeration), probe raw Modbus/TCP (function code 0x11 Report Server ID, 0x01 Read Coils).

Identifica PLC, controller industriali, sistema operativo embedded.

```
exa-dune modbus 192.168.1.100
```

upnp UPnP/SSDP audit — wraps nmap, curl SOAP

```
exa-dune upnp <TARGET> [--output DIR]
```

Esegue: SSDP M-SEARCH, download rootDesc.xml, enumera servizi UPnP, tenta AddPortMapping SOAP. Identifica device type, manufacturer, model, firmware version dal descrittore XML.

```
exa-dune upnp 192.168.1.1
```

ssl TLS/SSL full audit — wraps testssl.sh, sslscan, openssl, nmap ssl NSE

```
exa-dune ssl <TARGET> [--port PORT] [--output DIR]
```

Esegue: testssl.sh (protocolli, cipher suites, heartbleed, POODLE, BEAST, CRIME, robot), sslscan, openssl s_client certificate dump. Rileva: SSLv2/SSLv3, TLS 1.0/1.1, RC4, NULL cipher, self-signed cert, expired cert, weak keys.

```
exa-dune ssl 192.168.1.10 --port 443
```

tftp TFTP file enumeration — wraps atftp, nmap tftp-enum NSE

```
exa-dune tftp <TARGET> [--output DIR]
```

Tenta il download di file di configurazione comuni: startup-config, running-config, config.bin, AudioCodes.ini, sip.conf, extensions.conf, passwd, shadow, firmware.bin. Usa atftp o tftp in modalità non-interattiva. Lancia anche nmap tftp-enum NSE.

```
exa-dune tftp 192.168.1.10 # AudioCodes espone spesso config via TF
```

rtsp RTSP stream audit — brute-force path, accesso anonimo, stream capture

```
exa-dune rtsp <TARGET> [--port PORT] [--output DIR]
```

Esegue: DESCRIBE request su path comuni (/, /live, /stream, /video1, /h264/ch1/main/av_stream, /cam/realmonitor, /axis-media/media.amp, /h264Preview_01_main), nmap rtsp-url-brute e rtsp-methods NSE. Tenta cattura screenshot con ffmpeg se stream accessibile.

```
exa-dune rtsp 192.168.2.50 # Axis/Reolink camera
exa-dune rtsp 192.168.2.50 --port 10554 # Reolink alt port
```

js JavaScript analysis — estrazione endpoint, segreti, token, API keys

```
exa-dune js <TARGET> [--port PORT] [--scheme http|https] [--output
```

Scarica i file JavaScript dall'interfaccia web, analizza il contenuto cercando: API endpoint, token JWT, API keys, password in chiaro, URL interni, credenziali hardcoded. Usa grep con pattern per AWS keys, Google API, JWT (eyJ...), Basic Auth embedded.

```
exa-dune js 192.168.1.10 --port 443 --scheme https
```

dns

DNS enumeration — wraps dig, dnsrecon, host

```
exa-dune dns <TARGET> [--output DIR]
```

Esegue: dig ANY, PTR, MX, NS, TXT, SOA; zone transfer AXFR; dnsrecon brute-force sottodomini; reverse lookup range IP. Rileva zone transfer non autorizzate, record TXT con informazioni sensibili, sottodomini interni.

```
exa-dune dns 192.168.1.1 # DNS server lab
```

ipmi

IPMI/BMC audit — wraps nmap ipmi NSE, ipmitool

```
exa-dune ipmi <TARGET> [--output DIR]
```

Esegue: nmap ipmi-version NSE, ipmitool chassis status, test cipher suite 0 (bypass auth), dump hash IPMI con Metasploit

auxiliary/scanner/ipmi/ipmi_dumphashes se disponibile. Rileva IPMI 2.0 cipher-zero bypass.

```
exa-dune ipmi 192.168.1.200
```

coap

CoAP IoT protocol audit — wraps nmap coap NSE, coap-client

```
exa-dune coap <TARGET> [--output DIR]
```

Esegue: GET /.well-known/core (resource discovery), enumera risorse, tenta PUT/POST su risorse trovate senza autenticazione. CoAP è usato da sensori IoT, dispositivi embedded e gateway domotica.

```
exa-dune coap 192.168.1.40
```

vnc

VNC audit — wraps nmap vnc NSE, hydra brute-force

```
exa-dune vnc <TARGET> [--port PORT] [--passlist FILE]
```

Esegue: nmap vnc-info e realvnc-auth-bypass NSE, hydra brute-force. Rileva: accesso senza autenticazione (Authentication: None), RealVNC auth bypass, versione VNC, desktop OS.

```
exa-dune vnc 192.168.1.50
```

rdp RDP enumeration + brute-force — wraps nmap rdp NSE, hydra

```
exa-dune rdp <TARGET> [--port PORT] [--userlist FILE] [--passlist F
```

Esegue: nmap rdp-enum-encryption e rdp-vuln-ms12-020 NSE, hydra brute-force. Rileva: cifratura debole, NLA disabilitato, MS12-020 (DoS/RCE).

```
exa-dune rdp 192.168.1.60
```

ldap LDAP enumeration — wraps ldapsearch, nmap ldap NSE

```
exa-dune ldap <TARGET> [--port PORT] [--output DIR]
```

Esegue: bind anonimo ldapsearch (base DN, utenti, gruppi, OU), nmap ldap-rootdse e ldap-search NSE. Porta 389 (LDAP) e 636 (LDAPS). Rileva bind anonimo, espansione base DN, utenti e credenziali in chiaro.

```
exa-dune ldap 192.168.1.10 --port 389
```

post Post-exploitation — reverse shell multi-vector, file extraction

```
exa-dune post <TARGET> <ACTION> [--proto ssh|ftp|telnet|smb] [--use
```

Azioni disponibili: `shell` (reverse shell), `dump` (file extraction), `persist` (persistenza). Usa SSH, FTP, Telnet o SMB con le credenziali trovate. Genera payload Bash/Python/PowerShell per reverse shell.

```
# Reverse shell via SSH dopo credenziali trovate
exa-dune post 192.168.1.10 shell --proto ssh --user admin --pass ac
```

fw Firewall bypass — 32 tecniche di evasione/bypass

```
exa-dune fw <TARGET> [--tech all|LIST] [--ports LIST] [--sip-port N
```

OPZIONE	DESCRIZIONE
`--tech LIST`	Tecniche comma-separated: ack, altscans, srcport, frag, badsum, ipv6, upnp, sip-alg, decoy, ttl, datalen, slowscan, icmp, ftp-alg, http-tunnel, proto-confuse, knock, fullscan, iot-ports, snmp-recon. Default: all
`--ports LIST`	Porte TCP da testare (default: 22,23,80,443,445,5060,8080,8443,8554,21,25,53,554,2323)
`--sip-port N`	Porta SIP per test ALG pinhole (default: 5060)
`--probe-port N`	Porta da aprire con UPnP/SIP-ALG (default: 14444)
`--snmp-community STR`	Community SNMP nota (da pre-scan) per SNMP recon

```
# Tutte le tecniche (default)
exa-dune fw 192.168.1.10

# Solo tecniche specifiche
exa-dune fw 192.168.1.10 --tech ack,altscans,srcport,frag,ipv6
```

```
# Con community SNMP nota
exa-dune fw 192.168.1.10 --snmp-community public --tech snmp-recon,
```

report

Genera report da directory output — testo, HTML e PDF

```
exa-dune report <OUTPUT_DIR> [--html] [--pdf] [--output DIR]
```

Raccoglie tutti i findings.txt dall'albero di directory, aggrega per severità, genera report formattato. Con `--pdf` usa wkhtmltopdf o weasyprint per PDF. Il file viene copiato in `~/Desktop/EXA-DUNE-Reports/`.

```
# Genera solo testo
exa-dune report /root/pentest/exa-dune-192-168-1-10_20260325/

# Genera HTML + PDF
exa-dune report /root/pentest/exa-dune-192-168-1-10_20260325/ --htr
```

pipeline

Pipeline automatizzata 5 fasi: scan → suggest → attacchi → post-exploit → PDF

```
exa-dune pipeline <TARGET> [--auto] [--parallel] [--from-scan DIR]
```

OPZIONE	DESCRIZIONE
`--auto`	Non chiede conferma prima di eseguire gli attacchi suggeriti
`--parallel`	Lancia tutti i moduli in background in parallelo

`--from-scan DIR`	Usa un scan già esistente (salta la FASE 1)
`--no-post`	Salta la fase di post-exploitation anche se vengono trovate credenziali

Differenza da `auto`: pipeline usa un sistema di "suggest" basato sui risultati nmap (lista attacchi proposta all'utente), mentre `auto` è completamente automatico con 4 fasi predefinite incluso il bypass firewall.

```
# Pipeline automatica senza conferme
exa-dune pipeline 192.168.1.10 --auto

# Riusa scan esistente, lancia attacchi in parallelo
exa-dune pipeline 192.168.1.10 --from-scan /root/pentest/scan/ --pa
```

`onvif` ONVIF telecamere IP — service discovery, snapshot, PTZ, credenziali

```
exa-dune onvif <TARGET> [--port PORT] [--user U] [--pass P] [--outp
```

Esegue: GetSystemDateAndTime (senza auth), GetDeviceInformation, GetProfiles, GetStreamUri (URL RTSP stream), GetSnapshotUri, test credenziali default ONVIF. Identifica: vendor, modello, firmware, profili video, URL stream RTSP.

```
# Discovery ONVIF Axis
exa-dune onvif 192.168.2.50

# Con credenziali trovate
exa-dune onvif 192.168.2.50 --user root --pass pass
```

cam-cve

CVE scanner telecamere IP e VoIP — exploit noti vendor-specifici

```
exa-dune cam-cve <TARGET> [--vendor VENDOR] [--output DIR]
```

Vendor supportati: `hikvision`, `dahua`, `axis`, `reolink`, `audiocodes`, `commend`, `generic`. Testa CVE specifici per vendor: path traversal, backdoor, SSRF, RCE, config dump non autenticato. Se `--vendor` non specificato, prova tutti.

```
# CVE scan Axis specifica
exa-dune cam-cve 192.168.2.50 --vendor axis

# Scan generico (prova tutti i vendor)
exa-dune cam-cve 192.168.2.60
```

mdns

mDNS/Bonjour discovery — UDP 5353, dispositivi IoT auto-discovery

```
exa-dune mdns <TARGET> [--output DIR]
```

Interroga il target su UDP 5353 (mDNS). Molti dispositivi IoT, telecamere e gateway VoIP annunciano i propri servizi tramite mDNS (Avahi, Apple Bonjour). Usa nmap script dns-service-discovery e probe raw UDP. Estrae: nome device, servizi, IP, porte.

```
exa-dune mdns 192.168.1.10
```

wsd

WS-Discovery probe — UDP 3702, telecamere ONVIF e device embedded

```
exa-dune wsd <TARGET> [--output DIR]
```

Invia probe WS-Discovery (SOAP su UDP 3702). Standard usato da telecamere IP, NVR, DVR e altri device embedded per annunciare servizi ONVIF/WSDL. Estrae: deviceType, XAddrs (endpoint WSDL), scopes (vendor/modello/location).

```
exa-dune wsd 192.168.2.50
```

firmware

Analisi firmware — wraps binwalk, strings, credenziali hardcoded, certificati

```
exa-dune firmware <FILE_O_TARGET> [--download] [--output DIR]
```

Se viene passato un file binario: usa binwalk per estrarre filesystem, analizza con strings per credenziali hardcoded, certificati TLS, chiavi private, hash password. Cerca binari SUID, configurazioni con credenziali, file /etc/passwd e /etc/shadow. Se viene passato un TARGET: tenta prima di scaricare il firmware tramite TFTP o HTTP.

```
# Analizza firmware scaricato
exa-dune firmware /root/pentest/firmware.bin

# Scarica e analizza da device
exa-dune firmware 192.168.1.10 --download
```

bacnet

BACnet building automation audit — wraps nmap bacnet NSE, probe UDP:47808

```
exa-dune bacnet <TARGET> [--output DIR]
```

Esegue nmap bacnet-info NSE, probe raw BACnet/IP su UDP 47808. Identifica: vendor, modello, instance number, firmware, applicazione software (HVAC, accessi, illuminazione). Standard usato in automazione edifici.

```
exa-dune bacnet 192.168.1.100
```

enip

EtherNet/IP (CIP) audit — PLC Rockwell/Allen-Bradley, TCP:44818

```
exa-dune enip <TARGET> [--output DIR]
```

Esegue nmap enip-info NSE, probe CIP ListIdentity su TCP 44818. Identifica: vendor ID, device type, product code, revisione, serial number, nome prodotto. Rileva PLC industriali esposti sulla rete.

```
exa-dune enip 192.168.1.110
```

network-sweep

Discovery rete completo — trova tutti i device su una subnet

```
exa-dune network-sweep <SUBNET> [--output DIR] [--stealth]
```

Esegue: nmap -sn ping sweep sulla subnet, arp-scan per MAC discovery, identifica device attivi. Genera lista di target per assessment sequenziale.

Utile come primo passo per il laboratorio prima di lanciare auto su ogni device trovato.

```
# Discovery rete lab VoIP
exa-dune network-sweep 192.168.1.0/24 --output /root/pentest/sweep/

# Discovery rete lab telecamere
exa-dune network-sweep 192.168.2.0/24
```

7. Scenari Pratici di Laboratorio

Scenario 1 — VoIP Gateway AudioCodes MP20x `192.168.1.10`

L'AudioCodes MP20x è un gateway VoIP che espone tipicamente: interfaccia web HTTPS, SIP su UDP 5060, SNMP v2c, SSH, Telnet e TFTP. Questa procedura documenta un assessment completo.

Step 1: Discovery e scan

```
# Assessment automatico completo
exa-dune auto 192.168.1.10 --output /root/pentest/audiocodes-mp20x/

# Oppure: scan manuale per controllo completo
exa-dune scan 192.168.1.10 --vuln --output /root/pentest/audiocodes
```

Step 2: Enumerazione SIP

```
# Enumera estensioni SIP nel range 100-999
exa-dune sip 192.168.1.10 --range 100-999 --output /root/pentest/au
```

Step 3: Audit SNMP

```
# AudioCodes usa community 'public' per sola lettura
exa-dune snmp 192.168.1.10 --community public --output /root/pentes

# SNMP write test (community 'private' di default)
# Registra CRITICAL se community scrivibile trovata
```

Step 4: TFTP config dump

```
# AudioCodes espone spesso config via TFTP (porta UDP 69)
exa-dune tftp 192.168.1.10 --output /root/pentest/audiocodes-mp20x/

# File cercati: AudioCodes.ini, sip.conf, startup-config
# Spesso contengono credenziali SIP in chiaro
```

Step 5: CVE specifici AudioCodes

```
# Testa CVE vendor-specifici AudioCodes MP20x
exa-dune cam-cve 192.168.1.10 --vendor audiocodes

# Web audit interfaccia HTTPS
exa-dune web 192.168.1.10 --port 443 --scheme https
```

Step 6: Report

```
exa-dune report /root/pentest/audiocodes-mp20x/ --html --pdf
```

FINDING TIPICI AUDIOCODES MP20X

- Credenziali default Admin:Admin o Admin:1234 sull'interfaccia web
- SNMP community 'public' in lettura con sysDescr che rivela versione firmware
- TFTP esposto senza autenticazione con AudioCodes.ini scaricabile
- Interfaccia Telnet attiva con credenziali default
- SIP REGISTER senza autenticazione su alcune configurazioni

Scenario 2 — Telecamera IP Axis/Reolink `192.168.2.50`

Le telecamere IP Axis e Reolink espongono: interfaccia web HTTP/HTTPS, RTSP per lo stream video, ONVIF per interoperabilità, SNMP e a volte SFTP/FTP per backup.

Step 1: Discovery con WS-Discovery e mDNS

```
# Le telecamere si annunciano via WS-Discovery e mDNS
exa-dune wsd 192.168.2.50
exa-dune mdns 192.168.2.50
```

Step 2: Assessment automatico

```
exa-dune auto 192.168.2.50 --output /root/pentest/axis-cam/
```

Step 3: RTSP stream access

```
# Test accesso anonimo agli stream RTSP
exa-dune rtsp 192.168.2.50 --output /root/pentest/axis-cam/

# Reolink usa porta 10554 come alternativa
exa-dune rtsp 192.168.2.60 --port 10554 # Reolink

# URL stream Axis: rtsp://IP/axis-media/media.amp
# URL stream Reolink: rtsp://IP:554/h264Preview_01_main
```

Step 4: ONVIF enumeration

```
# GetDeviceInformation + GetStreamUri senza auth
exa-dune onvif 192.168.2.50

# Con credenziali default Axis (root:pass)
exa-dune onvif 192.168.2.50 --user root --pass pass
```

Step 5: CVE vendor-specifici

```
# CVE Axis (path traversal, backdoor root)
exa-dune cam-cve 192.168.2.50 --vendor axis

# CVE Reolink (config dump non autenticato, porta 9000)
exa-dune cam-cve 192.168.2.60 --vendor reolink
```

FINDING TIPICI TELECAMERE IP

- Axis: credenziali root:pass di default, path traversal su /admin/ non patchato
- Reolink: stream RTSP accessibile senza autenticazione, API HTTP senza auth su :9000
- ONVIF GetSnapshotUri senza autenticazione — snapshot del video senza credenziali
- SSL self-signed con certificato scaduto, TLS 1.0 abilitato

Scenario 3 — Device con Firewall (Bypass Workflow)

`192.168.1.20`

Questo scenario descrive la procedura quando il device risponde al ping ma nmap non trova porte aperte — tipico di device con firewall embedded o NAT stretto.

Step 1: Verifica manuale

```
# Il device risponde al ping ma nmap non trova nulla
ping -c 3 192.168.1.20  # OK
nmap -sS 192.168.1.20  # Tutti filtered
```

Step 2: auto gestisce il bypass automaticamente

```
# auto rileva il firewall e testa tutte le 32 tecniche
exa-dune auto 192.168.1.20 --output /root/pentest/device-fw/

# Oppure: test bypass manuale con tecniche selezionate
exa-dune fw 192.168.1.20 --tech ack,altscans,srcport,frag,ipv6,sip
```

Step 3: Se SNMP risponde, usa SNMP recon

```
# SNMP può rivelare porte interne anche se TCP è filtrato
exa-dune fw 192.168.1.20 --tech snmp-recon --snmp-community public

# Output: snmp_extra_ips.txt (IP interni), tcpConnTable (porte in a
```

Step 4: IPv6 bypass

```
# Molti firewall embedded non filtrano IPv6 link-local
# exa-dune calcola fe80:: e ripete lo scan
exa-dune fw 192.168.1.20 --tech ipv6

# Se trovato: exa-dune lancia service detection sulle porte bypasse
# e aggiorna open_tcp per la FASE 2
```

NOTA SUL BYPASS

Se tutte le 32 tecniche falliscono, exa-dune genera `no_access_summary.txt` con il registro di tutti gli approcci tentati e salta direttamente alla FASE 4 (report). Il report documenta l'impossibilità di accesso come finding informativo.

Scenario 4 — Discovery Rete Lab Completo

Procedura per scoprire tutti i device nel laboratorio e avviare assessment sequenziale.

Step 1: Network sweep

```
# Scopri tutti i device attivi nella rete VoIP
exa-dune network-sweep 192.168.1.0/24 --output /root/pentest/sweep-

# Scopri tutti i device nella rete telecamere
exa-dune network-sweep 192.168.2.0/24 --output /root/pentest/sweep-
```

Step 2: Assessment automatico su ogni device

```
# Leggi la lista host dal sweep e lancia auto per ognuno
for ip in $(grep "Host:" /root/pentest/sweep-voip/nmap_sweep.nmap
  exa-dune auto $ip --timeout 30 --output /root/pentest/lab-assessm
done
```

Step 3: Analisi risultati aggregati

```
# Trova tutti i finding CRITICAL nel laboratorio
grep -r "\[CRITICAL\]" /root/pentest/lab-assessment/*/findings.txt

# Genera report per ogni device
for dir in /root/pentest/lab-assessment/exa-dune-*/; do
  exa-dune report "$dir" --pdf
done
```

8. Cheat Sheet Rapido

ASSESSMENT AUTOMATICO

```
# Completo
exa-dune auto 192.168.1.10

# Stealth, timeout 30 min
exa-dune auto 192.168.1.10 \
  --stealth --timeout 30

# Con wordlist custom
exa-dune auto 192.168.1.10 \
  --userlist users.txt \
  --passlist pass.txt

# Riprendi interrotto
exa-dune auto 192.168.1.10 \
  --resume /root/pentest/DIR/

# Dry-run (preview)
exa-dune auto 192.168.1.10 --dry-run
```

SCAN E DISCOVERY

```
# Scan completo
exa-dune scan 192.168.1.10 --vuln

# Scan veloce no full
exa-dune scan 192.168.1.10 --no-full

# Discovery rete
exa-dune network-sweep 192.168.1.0/24

# mDNS discovery
exa-dune mdns 192.168.1.10

# WS-Discovery (telecamere)
exa-dune wsd 192.168.2.50
```

VOIP E SIP

```
# Enum SIP estensioni
exa-dune sip 192.168.1.10 \
  --range 100-999

# Brute-force SIP PIN
exa-dune sip 192.168.1.10

# SNMP AudioCodes
exa-dune snmp 192.168.1.10 \
  --community public

# TFTP config dump
exa-dune tftp 192.168.1.10

# CVE AudioCodes
exa-dune cam-cve 192.168.1.10 \
  --vendor audiocodes
```

TELECAMERE IP

```
# RTSP stream test
exa-dune rtsp 192.168.2.50

# RTSP porta Reolink
exa-dune rtsp 192.168.2.60 \
  --port 10554

# ONVIF discovery
exa-dune onvif 192.168.2.50

# CVE Axis
exa-dune cam-cve 192.168.2.50 \
  --vendor axis

# CVE Reolink
exa-dune cam-cve 192.168.2.60 \
  --vendor reolink
```

WEB E SSL

BRUTE-FORCE CREDENZIALI

```
# Web audit HTTPS
exa-dune web 192.168.1.10 \
  --port 443 --scheme https

# Web con fuzzing
exa-dune web 192.168.1.10 \
  --port 8080 --fuzz

# SSL full audit
exa-dune ssl 192.168.1.10

# JS analysis
exa-dune js 192.168.1.10 \
  --port 443 --scheme https
```

```
# SSH
exa-dune creds 192.168.1.10 ssh

# HTTPS custom wordlist
exa-dune creds 192.168.1.10 https \
  --port 443 \
  --userlist u.txt \
  --passlist p.txt

# FTP
exa-dune creds 192.168.1.10 ftp

# Telnet
exa-dune telnet 192.168.1.10
```

FIREWALL BYPASS

```
# Tutte le 32 tecniche
exa-dune fw 192.168.1.10

# Solo tecniche veloci
exa-dune fw 192.168.1.10 \
  --tech ack,altscans,srcport,frag

# IPv6 bypass
exa-dune fw 192.168.1.10 \
  --tech ipv6

# SNMP + IoT ports
exa-dune fw 192.168.1.10 \
  --tech snmp-recon,iot-ports \
  --snmp-community public
```

IOT/INDUSTRIAL PROTOCOLS

```
# MQTT broker
exa-dune mqtt 192.168.1.20

# Modbus ICS
exa-dune modbus 192.168.1.100

# UPnP/SSDP
exa-dune upnp 192.168.1.1

# CoAP IoT
exa-dune coap 192.168.1.40

# BACnet building
exa-dune bacnet 192.168.1.100

# EtherNet/IP PLC
exa-dune enip 192.168.1.110
```

REPORT E OUTPUT

```
# Genera report PDF
exa-dune report /root/pentest/DIR/ \
  --html --pdf

# Trova finding CRITICAL
grep -r "\[CRITICAL\]" \
  /root/pentest/DIR/*/findings.txt

# Trova credenziali trovate
find /root/pentest/DIR/ \
  -name "hydra_*.txt" \
  -exec grep "login:" {} \;
```

PIPELINE AUTOMATIZZATA

```
# Pipeline completa
exa-dune pipeline 192.168.1.10 \
  --auto

# Pipeline parallela
exa-dune pipeline 192.168.1.10 \
  --auto --parallel

# Da scan esistente
exa-dune pipeline 192.168.1.10 \
  --from-scan /root/pentest/scan/ \
  --auto --no-post
```

```
# Device profile
cat /root/pentest/DIR/device_profile.txt
```

9. Changelog

VERSIONE	DATA	NOVITÀ PRINCIPALI
v2.8.0 CORRENTE	25 Mar 2026	• **Firewall bypass avanzato a 32 tecniche**: aggiunto SNMP recon (ifTable/ipRouteTable/tcpConnTable), IoT vendor-specific ports (Dahua 37777, Hikvision 8000, Reolink 9000, MikroTik 8291, TR-069 7547, Asterisk AMI 5038), port knocking 10 sequenze, full port scan 1-65535 • **FASE 2 potenziata**: aggiunta rilevazione automatica vendor da SNMP OID enterprise (AudioCodes 591, Axis 368, Hikvision 507, Dahua 2560, Reolink 39165, Commend 3352), supporto Asterisk AMI completo (banner + login + SIPpeers dump), DLNA rootDesc + Content Directory, STUN, MGCP, H.248/Megaco, S7comm/Profinet, DNP3 • **Bugfix --timeout**: il valore timeout non veniva passato correttamente ai sotto-moduli di auto; ora ogni modulo è wrappato con `timeout N*60s` individuale • **NSE scripts mirati**: aggiunto MQTT mqtt-subscribe, RTSP rtsp-url-brute/rtsp-methods, SIP sip-enum-users/sip-methods, RDP rdp-vuln-ms12-020 • **SIP over WebSocket**: probe su porte web per HTTP Upgrade con Sec-WebSocket-Protocol: sip • **Banner grab CVE**: porte non standard → searchsploit automatico sul banner rilevato • **Quick default IoT creds**: 10 coppie testate con curl prima di hydra completo • **Rate limiting detection**: rileva HTTP 429/503 e backoff progressivo, adatta hydra

v2.7.0	15 Feb 2026	• Redesign completo del comando `auto`: architettura a 4 fasi (SCAN → ENUM → ATTACCHI → REPORT) con logica di branching a 3 rami • Pre-scan: aggiunto DNS reverse, ARP passivo (tcpdump), ICMP check con fallback -Pn, traceroute, mDNS, WS-Discovery, SNMP quick probe, HTTP HEAD, SSL cert grab • Post-scan: MAC vendor lookup da arp-scan, device profile consolidato • Checkpoint/resume: file .exa_checkpoint per ripresa assessment interrotti • Credential store .exa_creds.json per correlazione cross-service • Web auto-detection su porte dinamiche: ogni porta TCP aperta viene testata per HTTP/HTTPS • Aggiunto `network-sweep` per discovery subnet completa • Brute-force MQTT diretto con hydra e LDAP (ldap2) • IPMI cipher-zero bypass test automatico in FASE 3 • SNMP write community test in FASE 3
v2.5.0	10 Gen 2026	• 14 script ausiliari Python/JS/Shell per attacchi specializzati • Aggiunto modulo `firmware` con binwalk, credenziali hardcoded, cert TLS • Aggiunto modulo `cam-cve` con database CVE per 6 vendor • Aggiunto modulo `onvif` per telecamere ONVIF completo • Wordlist vendor-specifiche (audiocodes, axis, reolink, hikvision, dahua, commend) • JSON output per findings (--json-output flag) • Integrazione Metasploit per CVE check automatico • UPnP AddPortMapping injection test • DNS zone transfer automatico in FASE 3

v2.0.0	01 Nov 2025	• Prima versione con modulo `fw` per bypass firewall (16 tecniche iniziali) • Moduli: scan, web, sip, smb, creds, snmp, ftp, ssh, telnet, mqtt, modbus, upnp, ssl, tftp, rtsp, js, dns, ipmi, coap, vnc, rdp, ldap, post, report, pipeline • Wordlist embedded come fallback (8 categorie) • Output strutturato per directory con findings.txt aggregato

AGGIORNAMENTO

Controlla nuove versioni su GitHub: `exa-dune update` — esegue git pull e ricopia lo script in /usr/local/bin/exa-dune automaticamente.